



Lab 8 — Apply the PDPA and PDPC AI Advisory Guidelines

Topic 02: Building an AI Governance Framework: Policies, Roles and Risk Ownership

Objective: Evaluate the lawful basis for using personal data in AI systems under Singapore's PDPA and apply the PDPC AI advisory guidelines to four scenarios.

Goal: Singapore-specific compliance is where many AI projects stall. You will assess four NovaBank AI use cases against the PDPA obligations and the PDPC Advisory Guidelines on the Use of Personal Data in AI Recommendation and Decision Systems, and determine the lawful basis and the required notifications.

What you'll build: A PDPA compliance determination for four AI use cases, each with lawful basis, required notification, accountability measures and documentation.

Tools and data: PDPA scenario pack (pdpa-scenarios.md), PDPC guidelines summary, determination worksheet

Data files in this lab

- data/determination-worksheet.csv
- data/pdpa-scenarios.md
- data/pdpc-guidelines-summary.md

Step-by-step

1. Open pdpa-scenarios.md in labs/lab-08-pdpa-application/data/. The four scenarios are: a product recommendation model, a credit-decision support model, a staff-facing GenAI assistant, and a third-party developed fraud model.
2. For scenario 1, the recommendation model, assess whether the Business Improvement Exception applies. Check the purpose against the exception's conditions and record whether fresh consent is needed.
3. For scenario 2, the credit decision support model, note that it materially affects an individual. Determine the notification required and the human-oversight measure that must accompany the decision.
4. For scenario 3, the staff GenAI assistant, identify the risk that customer personal data is pasted into prompts. Determine the controls: data classification rules, input filtering, logging and retention limits.
5. For scenario 4, the third-party fraud model, identify the developer's status as a data intermediary and the Protection and Retention Obligations that follow, plus the contractual terms you require.

6. For every scenario record the Consent and Notification position: whether consent is relied on, whether an exception applies, and exactly what must be told to the individual.
7. Apply the Accountability Obligation to all four: what policies, records and internal processes must NovaBank be able to produce if the PDPC asks.
8. Record the data-protection measures the PDPC guidelines expect when personal data is used in AI development: minimisation, anonymisation or pseudonymisation where feasible, access control and retention limits.
9. Write the one-paragraph determination for each scenario: lawful basis, notification, controls, documentation and the residual legal risk you would escalate to the DPO.

Test it

Each of the four scenarios has a stated lawful basis with a reason. You can explain the difference between the Business Improvement Exception and the Research Exception in one sentence, and say which scenario needs the strongest human-oversight measure and why.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.